

Event Information:

☆ CVE-2023-22515 affects certain versions of Atlassian Confluence Data Center and Server, enabling malicious cyber threat actors to obtain initial access to Confluence instances by creating unauthorized

EventID :

197

Event Time :

Nov, 09, 2023, 09:47 AM

Rule :

SOC235 - Atlassian Confluence Broken Access Control 0-Day CVE-2023-22515

Level :

Security Analyst

Hostname :

Confluence Data Center

Destination IP Address :

172.16.17.234

Source IP Address :

43.130.1.222

HTTP Request Method :

GET

Requested URL :

/server-info.action?bootstrapStatusProvider.applicationConfig.setupComplete=false

User-Agent :

curl/7.88.1

Alert Trigger Reason :

This activity may be indicative of an attempt to exploit the CVE-2023-22515 vulnerability, which could potentially lead to create a new administrator user.

Device Action :

Allowed

Analysis Steps:

Logs were searched with IP 43[.]130.1.222 as the source and Confluence Data Center IP 172[.]16.17.234 as the destination in the relevant time-frame yielding 3 events. The attacker can be seen exploiting CVE-2023-22515, a critical broken access control vulnerability in Atlassian Confluence.

✓ 3 events (before Nov, 09, 2023, 09:48 AM UTC)

< Hide Fields	① Event
INTERESTING FIELDS	
α type	type Proxy
α source_address	source_address 43.130.1.222
# source_port	source_port 42312
α destination_address	destination_address 172.16.17.234
# destination_port	destination_port 80
α raw_log	time Nov, 09, 2023, 09:47 AM
	Raw Log
	Request URL /server-info.action?bootstrapStatusProvider.applicationConfig.setu... 🔍
	Request Method GET
	Response Code 200
	User-Agent curl/7.88.1
	1 row selected

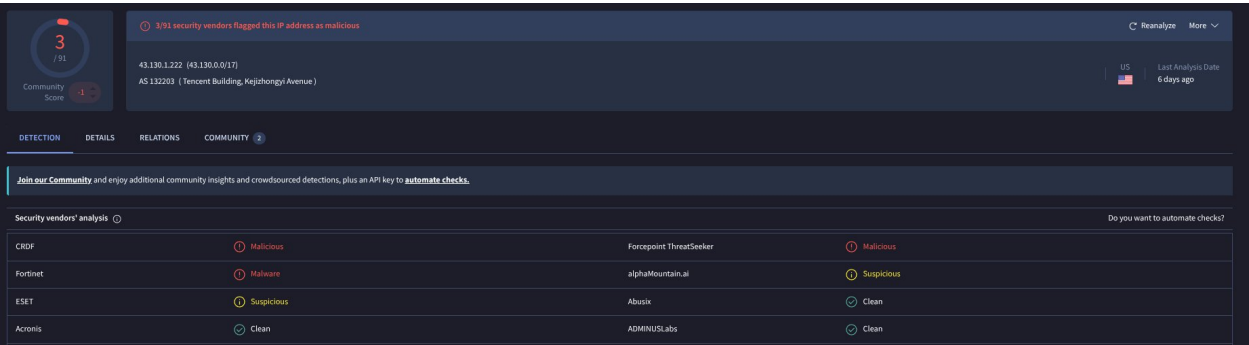
The steps the attacker took are as follows:

The attacker sends a GET request to /server-info.action with the parameter setupComplete=false. This tricks the Confluence server into thinking it is a brand-new installation that hasn't been set up yet, bypassing standard authentication.

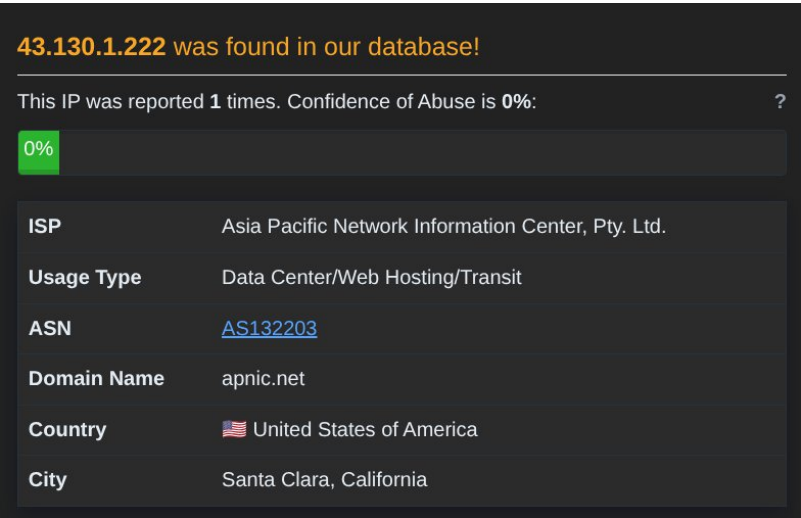
With the server tricked into setup mode, the attacker sends a POST request to /setup/setupadministrator.action. This command creates a new, unauthorised Confluence Administrator account. The 302 (Redirect) response code means the server successfully accepted the new user and pushed the attacker to the final step.

The attacker sends a POST request to /setup/finishsetup.action. The 200 (OK) response confirms they successfully exited the setup wizard and have unrestricted admin access.

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a US? (more likely Chinese) address associated with 43.130.1.222 AS 132203 (Tencent Building, Kejizhongyi Avenue). 3/91 security vendors flagged this IP address as malicious.



On AbuseIPDB. This IP was reported 1 time with a 0% confidence of abuse. Again strangely conflicting location data



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive exploit of CVE-2023-22515 (Broken Access Control) targeting the Confluence Data Center host (172[.]16.17.234). An external threat actor bypassed authentication by forcing the application into setup mode, subsequently creating an unauthorised administrator account.

Incident Details

- **Alert Name:** SOC235 - Atlassian Confluence Broken Access Control 0-Day CVE-2023-22515
- **Target Host:** Confluence Data Center (172[.]16.17.234)
- **Attacker IP:** 43[.]130.1.222
- **Device Action:** Allowed

Analysis and Evidence

- **Bypass Execution:** Proxy logs show the attacker initiated the exploit at 09:47 AM by sending a GET request to /server-info.action?bootstrapStatusProvider.applicationConfig.setupComplete=false. This successfully tricked the server into a pre-setup state, bypassing standard authentication.
- **Admin Creation:** The attacker immediately followed with a POST request to /setup/setupadministrator.action. The server responded with a 302 Redirect, indicating the unauthorised Confluence Administrator account was successfully created.
- **Exploit Confirmation:** At 09:48 AM, the attacker sent a final POST request to /setup/finishsetup.action, receiving a 200 OK response. This confirms the attacker successfully exited the setup wizard and secured unrestricted administrative access.

Threat Intelligence

- **OSINT (Infrastructure):** The attacking IP (43[.]130.1.222) is external and associated with AS 132203 (Asia Pacific Network Information Center / Tencent). Geolocation data is mixed, indicating potential proxying or cloud routing between Santa Clara, California, and China.
- **Reputation:** VirusTotal flags the IP as malicious with 3/91 vendor detections. AbuseIPDB shows 1 report with a 0% confidence of abuse.
- **Internal Correlation:** No internal Red Team testing or authorised penetration tests were scheduled involving this IP during the relevant time-frame.

Actions Taken

1. Analysed proxy logs to identify the complete CVE-2023-22515 exploit chain, including the setup mode bypass and subsequent rogue admin creation.
2. Verified exploit success by correlating the 302 Redirect and 200 OK HTTP response codes provided by the server during the admin creation phase.
3. Verified the attacker infrastructure via OSINT (VirusTotal, AbuseIPDB).
4. Declared the alert a successful True Positive compromise and escalated.

Let's Defend Result

SOC235 - Atlassian Confluence Broken Access Control 0-Day CVE-2023-22515

True Positive (+5 Point)

Was the Attack Successful? (+5 Point)

What Is the Direction of Traffic? (+5 Point)

Check If It Is a Planned Test (+5 Point)

What Is The Attack Type? (+5 Point)

Is Traffic Malicious? (+5 Point)